

on the network. Though the IDS systems do this job partially, there can be situations where the IDS could be too busy to be used as a packet viewer, and a FOSS utility can come in handy for daily chores.

4. Gather monitoring data at a secure place. It is often a mistake to gather security data on a desktop or a server which is easily accessible, making the network vulnerable at that point. Since security applies to the monitoring process too, the data captured must be stored in a secure manner.
5. Monitor all layers; don't leave anything to chance. Usually, the data link layer is omitted from monitoring; however, since a new wave of attacks can exploit Ethernet frames too, it is important to take this layer into account. The same applies to the network layer, as most internal attacks can easily use it to exploit vulnerabilities.
6. Deploy the IDS behind the firewall, since the firewall filters out everything that is not meant to enter the LAN. This improves the IDS' efficiency by keeping the clutter away.
7. Capture VLANs separately. Since VLANs are separate TCP broadcast domains, separately gathering and analysing data for each can help detect internal and external security problems quickly.
8. Consider all protocols. Many firms still use NetBIOS internally along with TCP/IP; such a situation demands monitoring all protocols on the wire. There are a few legacy types of attacks based on the NetBEUI protocol, which could be captured.
9. Enable optimal auditing levels on the monitoring devices. Setting up too many audit event captures can easily confuse monitoring solutions while detecting an anomaly, whereas having very few audit logs can render security monitoring useless.

It is a best practice to have an update in the monitoring process whenever a device is added to the network, removed or changed. Also, even if there is no change in the design, monitoring processes should be reviewed in a timely manner, in order to remove errors, and keep pace with changing security scenarios.

Monitoring network security using FOSS solutions

It is worth mentioning a few commercial products used in network security monitoring, before we talk about the FOSS solutions.

Cisco Security Monitoring, Analysis, and Response System (MARS) is a famous solution that falls in the category of Security Threat Mitigation systems (STM). MARS gathers and stores raw network data, and correlates it with intelligence algorithms. IBM Proventia IDS devices fall under the same category, providing richer features and customisable alerts. All these threat monitoring and mitigation appliances enable us to centralise detection, mitigation and reporting on priority threats by leveraging the network and security devices already deployed in a network.

In the FOSS world, the Backtrack Linux distribution is famous among cyber-security groups, as it allows one to write easy, effective and yet industry-standard utilities quickly. *Snorby* (www.snorby.org) is an open source suite of network security monitoring utilities, which interacts seamlessly with open source IDS solutions such as *Snort*, *Suricata*, etc. *Snorby* contains the necessary binaries to run on various operating systems, including Microsoft platforms.

Siem-Live is another such distribution gaining support and momentum. A good thing about this distribution is that it comes on a bootable CD, relies on generic IDS systems and log collectors, and applies intelligence on it to create customised reports. The event correlation engine of *Siem-Live* makes it fit for small- and mid-scale networks.

This article will be incomplete if a famous tool called *SGuel* is not mentioned here. While maintaining the quality of the intelligence engine, this tool comes with a nice GUI and essential bells and whistles, such as real-time event gathering, raw packet capturing, reporting, etc.

Summary

While there are numerous tools and practices available for monitoring the security of a network infrastructure, it is important to apply the industry's best practices. It is imperative for IT management teams to know what is happening on the network, in real-time, and accordingly introduce the latest technologies. Since cyber security is a process of continuous improvement, there cannot be a single list of best practices, as the quality of practices evolves with network architecture and design, as well as the devices in use. Network security monitoring is essential for the IT health of an organisation, and a rock-solid monitoring mechanism can help reduce damages to the business. While there are commercial solutions available for this, FOSS also provides real-time monitoring software and cutting-edge intelligence engines. Senior IT management personnel need to form a security monitoring group within the organisation to deploy the best practices and strengthen the corporate network. 

By: Prashant Phatak

The author has over 18 years of experience in the field of IT hardware, networking, Web technologies and IT security. For the past 11 years, he has worked in the USA as a VP (Global head of Technology Operations) at the Wall Street firm of Merrill Lynch (New York). Prashant is MCSE and MCDBA certified and is also a F5 load balancer expert. In the IT security world, he is an ethical hacker and net-forensic specialist.

Of late, Prashant has been running his own firm named Valency Networks in India (www.valencynetworks.com) providing consultancy in IT security, infrastructure technology and business process management. He can be reached at prashant@valencynetworks.com.